

The Hellenic Data Protection Authority convened, following an invitation from its President, in a regular session in the composition of a Section at its headquarters on 08/11/2023, in order to examine the case referred to in the background of this document. The session was attended via teleconference by Georgios Batzalexis, Deputy President, due to the absence of the Authority's President, Konstantinos Menoudakos, and the alternate members Demosthenes Bougioukas and Maria Psalla were present, as rapporteur in replacement of the regular members Konstantinos Lamprinoudakis and Grigoris Tsolias who were absent due to impediments despite being duly summoned in writing. Also present at the session, by order of the President without voting rights, were Charis Symeonidou, special scientist – auditor as assistant rapporteur, and Irini Papageorgopoulou, employee of the administrative affairs department of the Authority, as secretary.

The Authority took into account the following:

With the complaint No. G/EIS/7115/17-05-2022, A (hereinafter the complainant) is directed against Alpha Bank (hereinafter the complained party), of which he is a client, as the legal representative of the company ... O.E., alleging the non-satisfaction of the right of access to his personal data. Specifically, according to the complaint, following an incident of deception involving the representatives of the said company, who were victims of electronic fraud, through which money was transferred from the bank account at ..., the complainant went to branch F of the complained Bank, where he informed the manager, B, about the issue. Subsequently, with his extrajudicial protest dated ... to the complained Bank, which was served on ..., the complainant, among other things, exercised his right of access to all log files maintained by the Bank in relation to the interaction of their general partnership with the electronic platform (web banking) during the period ..., and to a copy of the visual material from the CCTV system of the branch, in which the aforementioned visit of the complainant on ... was recorded, according to Article 15 of the GDPR, as a natural person – data subject. As indicated in the initial complaint, with its message dated ..., the Bank informed the complainant that it "regrets the delay" and that his case remains under processing, without, however, informing him about the extension of the deadline of Article 12 par. 3 of the GDPR by one month and the reasons for the delay. Subsequently, as the complainant stated to the Authority in his supplementary complaint No. G/EIS/8311/27-06-2022, in response to his above request, he received the response from the complained Bank dated ... (G/EIS/9370/05-08-2022), with which the complained party, after providing him with the requested log files, informed him that his request for a copy of the video material could not be satisfied, as it was no longer maintained in its records due to the expiration of the retention period.

It is noted that with the extrajudicial protest dated ..., additional information was requested from the complained Bank regarding the preparation of a data protection impact assessment (Article 35 of the GDPR), any consultation with the Authority (Article 36 of the GDPR), any notification of a breach incident to the Authority (Article 33 of the GDPR), and regarding the security measures implemented by the complained party for the detection of suspicious transactions, which, however, do not fall within the information that the data subject is entitled to receive in the context of exercising the right of access according to Article 15 of the GDPR.

Subsequently, the Authority, in the context of investigating the above complaints to the extent of its competence, with the document G/EKE/2425/30-09-2022 communicated the relevant documents to the complained Bank and invited it to present its

****Opinions of the Respondent regarding the complaints, specifically to clarify the retention period of the video footage from the CCTV system of the Respondent and to provide any necessary documentation, particularly the relevant Data Retention Policy of the Bank as well as the relevant information provided to the data subjects.****

With its letter No. G/EIS/11065/17-10-2022, the Respondent Bank responded as follows:

1. That indeed, with the extrajudicial protest and request for access dated ..., the company ... O.E.

requested from the Bank, among other things, a "copy of the CCTV footage of ... between ... and ... which shows the visit of the legal representative to the Bank's branch and the communication with the Operations Manager of the branch, B."

2. That, as clearly indicated in the aforementioned request, the purpose of the access request was to prove the above visit to the branch and the communication with its manager.

3. That this purpose was achieved, beyond any doubt, with the letter from the Bank dated ... (note: attached to the complaint), which was received on the same day by the legal representative of the requesting O.E., in which it is stated that "we confirm that on ... at approximately ... Mr. A visited the Branch F (...) and informed the Operations Manager of Branch B regarding the above incident," namely the access of a third party to the account of the aforementioned company, since the necessary codes for this purpose leaked, according to the said response, from actions of the legal representative of the company.

4. That the above response was indeed sent by the Bank and received by the applicant on ..., "a few days after the expiration of the 30-day deadline set by the Regulation, on ..., due to the workload of the Bank's staff."

5. That, according to the relevant "information on the processing of image data carried out through closed-circuit television" of the Bank, which the Respondent attaches as Annex 1, the video footage is retained for a period of forty-five (45) days based on the relevant Directive of the Authority (1/2011, Article 16). Therefore, as the Respondent states, "the recordings of ..., a copy of which was requested on ... with the extrajudicial protest of the company, were deleted on ..., that is, before the expiration of the aforementioned deadline for the Bank's response on ...".

6. That, nevertheless, the Bank conducted all necessary internal investigations to document the above visit of the complainant and responded to the substantive part, as it states, of the client's request.

7. That there was no violation of personal data, nor of data concerning the legal entity of the limited partnership.

8. Finally, the Bank notes that the retention periods of its clients' personal data are mentioned in the Processing Activities Record and in the relevant updates to clients, which bind it, and for their implementation, a data destruction policy has been established, which it attaches as Annex 2 ("Cybersecurity and Information Security Framework of the Group – Data Destruction Procedure"), while the policy for retaining these, according to the Respondent, is in the process of completion and obviously follows the updates.

Following the above, the Authority, with calls No. G/EXE/733/22-03-2023 and G/EXE/735/22-03-2023, summoned the complainant and the Respondent to a hearing via videoconference before the Department of the Authority on 29/3/2023, in order to present their views on the case. During the session on 29/3/2023, the case was postponed at the request of the Respondent, for the session on 5/4/2023.

In the session on 5/4/2023, the complainant appeared via videoconference with his attorney, Vasileios Sotiropoulos (AM DSA ...), and on behalf of the Respondent Bank, the lawyers Ioannis Mourgelas (AM DSA ...), Theodoros Lalias (AM DSA ...), while G, the Data Protection Officer of the Bank, was also present. During the hearing, the parties presented their views, were given a deadline, and timely submitted, the complainant the memorandum No. G/EIS/3181/02-05-2023, and the Respondent the memorandum No. G/EIS/3245/03-05-2023.

The complainant, during the hearing, initially referred to the broader issue of electronic fraud against individuals and the theft of credentials through electronic phishing, following which monetary amounts are removed from their bank accounts. Regarding the examined issue of the failure to satisfy his right of access to the recorded material from the Bank's CCTV system, the complainant argued both during the hearing and in his memorandum that the complained Bank did not act in a timely manner, as it was required, on the request, and after the lapse of 54 days without action, refused to satisfy the request due to the expiration of the retention period (45 days according to the information provided on its

website). Furthermore, the complainant stated that the complained party deliberately did not satisfy his request in order to hinder the exercise of his legal claims, and in any case, the practice it follows is inconsistent with the information it provides to its customers. In his memorandum, the complainant emphasizes that the Bank acknowledged the fact that it did not timely satisfy the subject's right of access, while invoking Article 16 of Directive 1/2011 of the Authority, according to which "if during this time period (retention of the video material) incidents of organized economic fraud or disputes regarding financial transactions are recorded, the relevant sections of the data from the video surveillance system may be kept in a separate file with appropriate security measures for as long as required for the investigation or disciplinary or judicial prosecution of these incidents" and argues that the complained party did not comply with the relevant directive of the Authority for the "freezing" of the data when an illegal act has been committed, which, according to the complainant, constitutes an obligation of the data controller as a security measure according to Article 32 of the GDPR. Additionally, the complainant invokes decisions 47/2018, 32/2017, and 170/2014, which have previously imposed sanctions on the complained party for violations or delays in satisfying the right of access to personal data.

Furthermore, the complainant, in his memorandum, argues that by exception, the GDPR applies to legal entities when it concerns partnerships, in which case any information regarding the company also pertains to the partners as natural persons, a claim that is made inextricably in this case, since beyond the visual material from the video surveillance system, the other requested information in the request dated ... by the complainant does not fall within the information that the subject is entitled to receive in the context of exercising the right of access according to Article 15 of the GDPR, as previously mentioned. It is also noted that the requested log files of actions that had been performed through the complainant's corporate account on the electronic platform (web banking) were provided by the complained Bank to the complainant.

The complained Bank, both during the hearing and in its memorandum G/EIS/3245/03-05-2023, reiterated its aforementioned claims and additionally argued the following:

- That indeed, due to workload, it delayed responding within the thirty (30) day deadline to the access request submitted on ..., and responded to it on ..., resulting in the requested recording of ... being deleted on ..., according to its policy for retaining video material for 45 days. However, according to the complained Bank, the purpose of exercising the right was to prove the complainant's visit to the branch on that specific day, and this purpose was "fully satisfied" with the written confirmation of that visit and the complainant's conversation with a specific employee of the Branch through the letter dated ... from the Bank.

- That according to the General Terms of Conducting Banking Transactions, which it submitted with its memorandum and which the complainant accepted upon entering into the web banking contract, "the Customer accepts that any transaction executed through the Alternative Networks after accessing them using the Personal Identification Codes and, if applicable, the additional security code ... is considered by the Bank as originating from and approved by him" (paragraph 8.2.1).

- That the complainant and legal representative of the partnership ... O.E., due to being deceived on ..., was misled and disclosed to an unknown third party their...

passwords to the e-banking platform of the aforementioned general partnership, as well as the additional OTP security code received on his mobile phone, resulting in the execution of the debit order that the unknown third party gave to the bank using the above identifiers, while no security incident was recorded in the Bank's systems nor any incident of personal data breach.

- During the hearing, it was also clarified by the Bank that the codes and other access credentials of a person to e-banking serve to identify them in the system and do not lead to automated decision-making or profiling within the meaning of Article 22 of the GDPR. Finally, the Bank additionally referred to issues outside the subject matter of the complaint under examination, such as the practices it follows regarding the general information of its customers for their protection against electronic fraud and the detection of suspicious transactions. The Authority reserves the right to examine ex officio, at its discretion, any issues related to the technical and organizational security

measures of the complained Bank, which were mentioned incidentally during the hearing and which were not the subject of the complaint.

The Authority, after examining the contents of the file and having heard the rapporteur and the clarifications from the assistant rapporteur, who attended without voting rights, following a thorough discussion,

CONSIDERED IN ACCORDANCE WITH THE LAW

1. From the provisions of Articles 51 and 55 of the General Data Protection Regulation (Regulation (EU) 2016/679 – hereinafter, GDPR) and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data. Specifically, from the provisions of Articles 57(1)(f) of the GDPR and 13(1)(g) of Law 4624/2019, it follows that the Authority has the competence to address the complaint of A against Alpha Bank and to exercise, correspondingly, the powers granted to it by the provisions of Articles 58 of the GDPR and 15 of Law 4624/2019.

2. With Article 5(1) of the General Regulation (EU) 2016/679 for the protection of natural persons against the processing of personal data (hereinafter GDPR), the principles that must govern a processing are established. According to Article 5(1)(a) and (f) GDPR, "1. Personal data shall be: (a) processed lawfully, fairly, and in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency'), [...]. Furthermore, according to the accountability principle expressly defined in the second paragraph of the same article and which constitutes a cornerstone of the GDPR, the data controller "is responsible for, and must be able to demonstrate compliance with, paragraph 1 ('accountability')". This principle entails the obligation of the data controller to be able to demonstrate compliance with the principles of Article 5(1).

3. According to the definition in Article 4(2) GDPR, processing means "any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording (...) deletion or destruction" of the data. Furthermore, any processing operation must be based on at least one of the legal bases of Article 6 GDPR to be lawful.

4. According to the provisions of Article 15(1) and (3) GDPR: "1. The data subject has the right to obtain from the data controller confirmation as to whether or not personal data concerning him or her is being processed and, if that is the case, the right of access to the personal data [...]. 3. The data controller shall provide a copy of the personal data undergoing processing. For any additional copies that may be requested by the data subject, the data controller may charge a reasonable fee for administrative costs. If the data subject submits the request by electronic means and unless the data subject requests otherwise...

something different, the information is provided in an electronic format that is commonly used."

Furthermore, according to Article 12(3) of the GDPR, "The data controller shall provide the data subject with information regarding the action taken in response to a request under Articles 15 to 22 without undue delay and in any event within one month of receiving the request. This period may be extended by two further months where necessary, taking into account the complexity of the request and the number of requests. The data controller shall inform the data subject of any such extension within one month of receiving the request, as well as the reasons for the delay. If the data subject submits the request by electronic means, the information shall be provided, where possible, by electronic means, unless the data subject requests otherwise." Furthermore, it does not matter for what purpose the data subject exercises the right of access. According to the Authority's case law, the GDPR does not impose conditions for its exercise, which is linked to the data subject's ability to be aware of the processing and to verify the lawfulness of the processing (APD 1/2022). Thus, there is no requirement to state the reasons for which the data subject wishes to exercise the right of access (see APD decisions 36/2021, 2/2020, and 16/2017, para. 3). The same is also emphasized in the Guidelines 1/2022 of the EDPB regarding the right of access, see in particular para. §13: "...the aim of

the right of access is not suitable to be analyzed as a precondition for the exercise of the right of access by the controller as part of its assessment of access requests. Thus, controllers should not assess 'why' the data subject is requesting access, but only 'what' the data subject is requesting."

5. According to Article 16(2) of the Authority's Directive 1/2011 regarding the Use of Video Surveillance Systems for the Protection of Persons and Property: "2. Banks and financial institutions may retain data for a period not exceeding forty-five (45) days. If incidents of organized economic fraud or disputes regarding financial transactions are recorded during this period, the relevant sections of the data shall be retained..."

****6.**** In this case, given the aforementioned factual circumstances, it is established that the complained Bank, although it received on ... a request from the complainant as a subject for access to the recorded visual material from the CCTV system of Branch F on ... prior to the expiration of 45 days from the recording, that is, at a time when the material was still being retained according to the Bank's policy, subsequently proceeded to destroy this material on ... and responded to the complainant on ... (13 days after the expiration of the 30-day deadline of Article 12, paragraph 3 of the GDPR) that the requested material had been destroyed based on the said policy, while it satisfied his request regarding the recorded accesses to web banking (log files). The written confirmation to the complainant, in the same letter, that a visit to the branch had taken place on ... at ..., does not constitute satisfaction of the right of access to a copy of the data under Article 15, paragraph 3, considering that the presumed purpose of the subject for which the right is exercised should not concern the data controller, who is obliged to satisfy it without examining the motives of the subject and is not exempt from this obligation by responding at his discretion "to the substantive part of the subject's request." Therefore, the complained Bank violated the provision of Article 15, paragraphs 1 and 3 of the GDPR in conjunction with Article 12, paragraph 3 of the GDPR.

****7.**** Furthermore, it is noted that the deletion or destruction (on ...) of the CCTV visual material that included the recording of the complainant's visit on ... after the exercise of the subject's right of access as a data processing act took place by the complained Bank without ...

****8.**** Based on the above, from the documents in the file and following the hearing process, the Authority finds that the reported Bank, as the data controller, has violated Article 15 of the GDPR in conjunction with Article 12(3) of the GDPR, because the reported entity did not provide the requested copy of the audiovisual material recording the visit of the complainant to Branch F on ... to the complainant as the data subject and did not inform him within one month of receiving the access request about the extension of the deadline and the reasons for the delay. Furthermore, there is a violation of the principle of lawfulness of processing (Article 5(1)(a) of the GDPR in conjunction with Article 6 of the GDPR) due to the destruction of the file of the aforementioned audiovisual material after the exercise of the data subject's right of access and before it was provided to the data subject, resulting in making it impossible to satisfy the right.

****9.**** Based on the above, the Authority deems it appropriate to exercise its corrective powers under Article 58(2) of the GDPR concerning the identified violations and that, based on the circumstances established, an effective, proportionate, and deterrent administrative monetary fine should be imposed under Article 83 of the GDPR, both to restore compliance and to punish the unlawful behavior. Furthermore, the Authority took into account the criteria for determining the fine set out in Article 83(2) of the GDPR, paragraph 5(a) and (b) of the same article applicable to the present case, the Guidelines for the application and determination of administrative fines for the purposes of Regulation 2016/679 issued on 03-10-2017 by the Article 29 Working Party (WP 253), and the Guidelines 04/2022 of the European Data Protection Board for calculating administrative fines under the General Regulation, as well as the factual data of the examined case and particularly:

- a) the fact that the reported Bank violated the fundamental principle of lawfulness, fairness, and transparency of processing as provided by Article 5(1)(a) of the GDPR, as well as the provision of Article 15 of the GDPR, violations that fall under the highest category of the administrative fine grading system according to the provision of Article 83(5)(a) and (b) of the GDPR.
- b) The fact that the processing related to the violation is not connected to the core activity of the reported Bank.

c) The fact that the violation is isolated, of low severity, and concerns an individual.

d) The fact that the violation is due to the fault of the reported entity, which did not handle the request in a timely manner (thus also violating the provision of Article 12(3) of the GDPR) and that the cited reason (workload) indicates negligence. Moreover, the Bank, as a data controller handling a large volume of personal data, is required to have appropriate procedures and mechanisms for the timely handling of requests from data subjects.

****Data for the exercise of their rights under the GDPR, as noted by the EDPB in Guidelines 01/2022 on the right of access.****

e) The fact that the complainant, as the data controller, took actions to mitigate the adverse consequences of the violation on the data subject, with the letter dated ..., through which the date and time of the complainant's visit to the specific establishment was confirmed, while it was not established that the failure to provide the visual material caused further harm to the data subject.

f) The fact that in the past, the same Bank has been imposed sanctions for failure to satisfy the right of access (see Decisions 47/2018, 170/2014).

Based on the above, the Authority unanimously decides that an administrative sanction, as mentioned in the operative part, must be imposed on the complainant ALPHA BANK S.A. as the data controller, which is deemed proportionate to the severity of the violations.

****FOR THESE REASONS****

THE AUTHORITY

Imposes on ALPHA BANK S.A. an administrative fine of ten thousand (10,000 €) euros for the failure to satisfy the complainant's right of access to their personal data in violation of the provisions of Articles 15(1) and (3) GDPR and 12(3) GDPR and for the unlawful deletion of such data in violation of the provisions of Article 5(1)(a) GDPR.

****The President****

Georgios Batzalexis

****The Secretary****

Irini Papageorgopoulou

2 “Nevertheless, a controller, especially one who handles a large quantity of data, should have procedures and mechanisms in place in order to be able to handle requests within the time limit under normal circumstances.” (EDPB Guidelines 01/2022 on data subject rights - Right of access Version 2.0, §164)